

Face & Gesture Data

Current state, collection plan, and App Review risk · Vidrip — internal planning & App Store 2.1

TL;DR recommendation

1. **For the current (rejected) submission: collect nothing new.** Answer Apple's 2.1 question truthfully about what exists today (on-device detection, minimal *functional* landmark storage) and pass review. Adding new face-data collection in the same cycle Apple is already scrutinizing face data is the fastest way to get rejected again.
2. **Next release: add gesture analytics as opt-in, on-device-derived, non-identifying events** (e.g. "smiled at 0:03", "laughed at 0:11") — not raw biometrics, not a faceprint. This gives almost all the product value at the lowest legal/review risk.
3. **Never store a face template / embedding / faceprint** (anything that can *identify* a person from their face). That single line is the difference between "sensitive usage data" and "biometric identifier" — the latter triggers BIPA-class laws with per-violation statutory damages and much harsher review.

1. What we store TODAY (so we're precise with Apple)

Face detection runs **100% on-device** (MediaPipe Face Landmarker via a VisionCamera frame processor). No cloud face processing, no third party.

We **do** persist a small amount of face geometry, but only:

- **when the user actively wears an AR lens while recording**, and
- **only for studio/channel clips** (friend-share reactions store *no* landmarks), and
- as part of the video's `overlay_recipe` JSON.

What's stored = a **FaceLensTrack**: per-frame anchor points (eye/nose/mouth, face width, head roll) + optionally a *sparse* mesh contour (~150 of 478 points), quantized to integers. Its purpose is **functional** — to re-render the lens on playback. We do **not** store: face images/frames, RGB pixels, blendshapes, gaze/iris, or any face template/embedding.

So the honest answer to Apple is: "*on-device only; we store sparse facial-landmark geometry solely to re-render an optional cosmetic AR effect; it's not a biometric identifier and isn't used to identify anyone.*" That answer passes.

2. The taxonomy of what we *could* collect (value vs. risk)

Signal	Product value	Identifies a person?	Risk tier	Verdict
Derived gesture events (smile, laugh, surprise, frown, nod,	High — reaction analytics, auto-emoji, highlight detection,	No (derived, non-	Low	✅ Collect (opt-in, next release)

Signal	Product value	Identifies a person?	Risk tier	Verdict
head-shake, brow-raise, "looked away") with timestamp + intensity	engagement scoring	identifying)		
Aggregate reaction scores (positivity, intensity, # of laughs, attention %) per reaction	High — creator analytics, ranking, "best reactions"	No	Low	✅ Collect (opt-in)
Blendshape coefficient timeline (52 ARKit-style: jawOpen, mouthSmile, eyeBlink, browInnerUp...)	Medium — richer expression modeling, better classifiers	Not on its own (but granular)	Medium	⚠️ Only if needed; keep on-device, upload sparingly
Head pose (pitch/yaw/roll) + gaze direction	Medium — attention/engagement	No (pose), gaze is more sensitive	Medium	⚠️ Pose ok; treat gaze cautiously
Full 478-pt mesh timeline	Low (beyond rendering)	Approaches face geometry	High	🚫 Don't store for analytics (keep only the functional sparse track)
Face embedding / template / "faceprint"	Low here	Yes — uniquely identifies	Severe	🚫 Never
Raw camera frames / face crops as data	Low	Yes	Severe	🚫 Never

The line that matters: **derived, non-identifying signals** ("this person smiled") sit in normal sensitive-usage-data territory. The moment you store something that can **recognize/identify** a person from their face (a template/embedding), you're handling a **biometric identifier**.

3. Review & legal risk

Apple App Review

- **2.1 (the current rejection):** must fully disclose what face data is collected, every use, sharing, storage, retention — and have a privacy policy that says so. Answerable today; gets harder the more you collect.
- **5.1.1 / 5.1.2 (privacy & data use):** collection must be tied to a disclosed purpose, require **consent**, and you can't use the data beyond what you told the user. Gather consent before collecting.
- **App Privacy "nutrition label"** (App Store Connect): you must declare the data types. Derived expression/usage signals → declare under usage data / "Other"; a faceprint would be "Sensitive Info / biometric" and draws scrutiny.
- Apple is fine with on-device face detection for effects (Snapchat/TikTok do it). The risk spikes when face-derived data is **uploaded/stored** and especially if it could **identify** someone.

Privacy law (this is the real exposure)

- **Illinois BIPA:** if you collect a **biometric identifier** (a faceprint/scan of face geometry used to identify), you must get **written consent**, publish a **retention + destruction schedule**, can't **sell/profit** from it, and face **statutory damages (\$1,000–\$5,000 per violation)** — class actions have cost companies hundreds of millions. Texas (CUBI) and Washington have similar regimes.
 - **Mitigation: don't create identifiers.** Derived events ("smiled") are generally *not* biometric identifiers. Keeping signals non-identifying is the single most important risk control.
- **GDPR / CCPA-CPRA:** face/biometric data is *special category / sensitive personal information* → explicit opt-in consent, purpose limitation, data-subject access/delete, possibly a DPIA. Even non-identifying expression data tied to a user is "sensitive" and should be opt-in + deletable.

4. Recommended phased plan

Phase A — THIS submission (no new collection)

- Ship the 2.1 answer describing today's on-device, functional, non-identifying landmark storage.
- Publish/point to a Privacy Policy that includes the face-data section (draft below / to host at vidrip.app/privacy).
- (Optional hardening) Confirm the stored mesh is sparse + functional; keep "anonymous mode" (silhouette) available. Nothing else changes. → **Goal: pass.**

Phase B — next release (opt-in gesture analytics)

1. **On-device classification.** The existing frame processor already yields landmarks (and can yield blendshapes). Add an on-device classifier that maps expression → discrete **events**: `{ t: ms, type: 'smile'|'laugh'|'surprise'|'frown'|'nod'|'shake'|'browRaise'|'lookAway', intensity: 0..1 }`. No raw landmarks leave the device for analytics.
2. **Store derived signals only.** New record `reaction_signals` (or a `signals` JSON on the reaction/post): the event array + aggregate scores (positivity, intensity, peaks, attention%). Tied to the reaction + the source-video timestamp.
3. **Consent gate (opt-in, default OFF).** A clear toggle — e.g. *"Help improve reactions with on-device expression signals (smiles, laughs). Processed on your device; we store only the gesture events, never your face or anything that identifies you."* Surface it at first lens/record use; respect it everywhere; easy to turn off.
4. **Privacy posture:** declare in the App Privacy label; document use/retention in the policy; delete signals on video deletion and on account deletion; set a retention limit.
5. **Hard "never" list:** no face templates/embeddings, no face crops as data, no selling, no third-party sharing, no using it to identify/authenticate users.

Product payoffs unlocked by Phase B

Auto-suggested emoji reactions; "reaction highlights" (jump to the laugh); engagement/positivity scores for creators; better feed ranking; A/B which content lands — all from non-identifying derived events.

5. Privacy-policy face-data section (draft — host at vidrip.app/privacy)

Camera & face effects. When you record a reaction, Vidrip uses your camera. If you choose an AR "lens," your device detects facial landmarks **on your device** to position the effect. This detection is performed locally using on-device machine learning; **raw camera frames and facial geometry are not sent to our servers** for this purpose. When a lens is used, a compact set of facial *landmark coordinates* (not images, not a faceprint) is saved with your video so the effect can be re-rendered on playback. We do **not** create a face template, do **not** use face data to identify you, and do **not** share it with third parties. You can delete your videos at any time, which removes this data.

Optional expression signals (if enabled). If you opt in, Vidrip derives non-identifying gesture *events* (e.g. smiled, laughed) on your device to improve reaction features. We store only these events and summary scores — never your face, images, or any data that identifies you from your appearance. You can disable this anytime; the data is deleted with your videos and on account deletion.

(Use only the first paragraph until Phase B ships.)

6. App Store Connect 2.1 reply (current submission — use as-is)

- **What face data does the app collect?** Only when a user enables an optional AR lens while recording: sparse facial-landmark coordinates (eye/nose/mouth anchor points + head roll, plus an optional sparse face-outline mesh). No face images, no biometric template, no blendshapes, no gaze/iris.
- **All planned uses?** Solely to position and render the cosmetic AR effect, and to re-render it on playback. Not used for identification, authentication, advertising, or analytics.
- **Shared with third parties? Where stored?** Not shared with any third party. Detection runs on-device (MediaPipe, no cloud). The landmark coordinates are stored with the user's own video in our backend (Supabase).
- **Retention?** Kept as part of the video's render recipe; deleted when the user deletes the video or their account.
- **Where in the privacy policy?** Section "Camera, Microphone & Face Data" at vidrip.app/privacy.